

WEB APPLICATION

SECURITY ASSESSMENT REPORT

Panchsheel School Infrastructure

Target Domain	panchsheelschool.com
Assets Assessed	erp.panchsheelschool.com online.panchsheelschool.com
Assessment Date	March 17 – 18, 2026
Report ID	PST-2026-004
Methodology	OWASP Testing Guide v4, PTES
Classification	CONFIDENTIAL
Overall Risk	HIGH

PREPARED BY

Sahil Maurya

Student · GLA University

sahilmaurya2575@gmail.com

sahilmaurya.in/portfolio | github.com/sahilmaurya2006

Table of Contents

1. Executive Summary
2. Scope & Infrastructure
3. Methodology
4. Consolidated Findings
 - 4.1 FIND-001 · Crystal Reports Component Exposure & Directory Listing
 - 4.2 FIND-002 · Legacy ActiveX Components & Client-Side Execution Risk
 - 4.3 FIND-003 · Legacy ASP.NET Framework Version Disclosure
 - 4.4 FIND-004 · Publicly Exposed RDP Service (Port 3389)
 - 4.5 FIND-005 · External Third-Party Script Inclusion (Supply Chain Risk)
 - 4.6 FIND-006 · Improper HTTPS / TLS Configuration
 - 4.7 FIND-007 · Default IIS Page Exposure
5. Risk Assessment Matrix
6. Realistic Attack Chain
7. Evidence Summary
8. Remediation Roadmap
9. Conclusion

1. Executive Summary

A consolidated security assessment of Panchsheel School's web infrastructure — comprising **erp.panchsheelschool.com** and **online.panchsheelschool.com** — was conducted on March 17–18, 2026 using OWASP Testing Guide v4 and the Penetration Testing Execution Standard (PTES). The assessment identified **seven distinct security findings** spanning information disclosure, legacy component exposure, network misconfiguration, and supply-chain risk.

OVERALL RISK RATING

HIGH

Key Observations:

- Public exposure of Crystal Reports viewer components and directory listing enabled on sensitive paths.
- Legacy ASP.NET 2.0 / 4.0 framework version disclosed via server response headers.
- Publicly accessible ActiveX CAB packages containing executable components and DLLs.
- Remote Desktop Protocol (RDP, Port 3389) accessible from the public internet.
- External third-party JavaScript inclusion from an unverified CDN domain (supply chain risk).
- Inconsistent HTTPS enforcement — fallback to unencrypted HTTP observed.
- Default IIS page exposed at the server root, revealing configuration details.

Note: No direct server-side exploitation (e.g., Remote Code Execution, IDOR, SSRF) was performed or confirmed during this assessment. All findings are based on passive reconnaissance, directory enumeration, and static analysis. The identified issues collectively represent a HIGH risk posture due to their potential for chained exploitation.

2. Scope & Infrastructure

Asset	Description	Protocol
erp.panchsheelschool.com	ERP web application	HTTP/HTTPS
online.panchsheelschool.com	Online portal	HTTP/HTTPS
/aspnet_client/ (paths)	Static client-side components	HTTP
Port 3389 (same IP)	RDP service	TCP

Infrastructure Component	Details
Cloud Provider	AWS EC2 (Region: ap-south-1)
Operating System	Windows Server
Web Server	Microsoft IIS 10
Secondary Server	Nginx (detected)
Framework	ASP.NET 2.0 (path) / ASP.NET 4.0 (header)
Reporting Tool	SAP Crystal Reports v13

Researcher Profile

Field	Details
Name	Sahil Maurya
Role	Student — Security Researcher
Institution	GLA University
Email	sahilmaurya2575@gmail.com
Portfolio	https://www.sahilmaurya.in/portfolio
GitHub	https://github.com/sahilmaurya2006
Assessment Type	Independent Responsible Disclosure Research
Report Date	March 18, 2026

3. Methodology

Reconnaissance: Subdomain enumeration (subfinder), network/port scanning (nmap), passive OSINT.

Discovery: Directory brute-forcing (ffuf with SecLists wordlists), manual endpoint probing.

Analysis: HTTP response header inspection, JavaScript/resource analysis, CAB/INF file inspection, binary static analysis.

Standards Applied: OWASP Testing Guide v4 (OTG), Penetration Testing Execution Standard (PTES).

Scope Limitation: No active exploitation performed on production systems. All binary analysis was conducted in an isolated local environment.

4. Consolidated Findings

ID	Finding	Severity	CVSS
FIND-001	Crystal Reports Component Exposure & Directory Listing	HIGH	7.5
FIND-002	Legacy ActiveX Components & Client-Side Execution Risk	MEDIUM	6.1
FIND-003	Legacy ASP.NET Framework Version Disclosure	HIGH	7.1
FIND-004	Publicly Exposed RDP Service (Port 3389)	HIGH	8.1
FIND-005	External Third-Party Script Inclusion (Supply Chain)	MEDIUM	6.5
FIND-006	Improper HTTPS / TLS Configuration	MEDIUM	5.9
FIND-007	Default IIS Page Exposure	MEDIUM	5.3

FIND-001: Crystal Reports Component Exposure & Directory Listing

HIGH

CVSS v3.1 Score: 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

Description: Directory listing is enabled on multiple Crystal Reports viewer paths, making internal application resources publicly accessible without authentication. Affected paths include: /aspnet_client/system_web/2_0_50727/crystalreportviewers13/, /aspnet_client/system_web/4_0_30319/crystalreportviewers13/, and /aspnet_client/system_web/2_0_50727/crystalreportviewers13/ActiveXControls/. Exposed resources include JavaScript files (promptengine_prompts2.js), HTML interface components, ActiveX CAB archives (PrintControl.cab, crv13.cab), INF installation scripts, and legacy DLL references.

Impact: Disclosure of internal application logic and reporting architecture. Technology fingerprinting enabling targeted attacks. Exposure of legacy components susceptible to reverse engineering. Facilitates attacker reconnaissance and attack surface mapping for subsequent exploitation phases.

Evidence:

```
GET /aspnet_client/system_web/2_0_50727/crystalreportviewers13/ HTTP/1.1 Server
returns: Index of /aspnet_client/system_web/.../crystalreportviewers13/
```

Recommendation: Disable directory listing in IIS (set directoryBrowse enabled='false'). Restrict public access to /aspnet_client/ via web.config or IIS authorization rules. Remove or replace ActiveX-based Crystal Reports components with modern web alternatives. Serve only required static assets; relocate internal resources behind authentication.

FIND-002: Legacy ActiveX Components & Client-Side Execution Risk**MEDIUM****CVSS v3.1 Score:** 6.1 (AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N)

Description: The publicly accessible CAB file at /ActiveXControls/PrintControl.cab contains: PrintControl.dll (ActiveX control), DependencyInstaller.exe (installer executable), multiple DLL dependencies, and a PrintControl.INF file confirming RegisterServer=yes with CLSID {B7DA1CA9-1EF8-4831-868A-A767093EA685}. Static analysis of extracted binaries reveals debug path disclosure: d:\crell\win32_x86\release\pdb\crystalreports.cpp\DependencyInstaller.pdb, indicating an unstripped production binary. Note: All binary analysis was performed locally; no exploitation was attempted on production systems.

Impact: Exposure of installable ActiveX controls creates a client-side attack surface for legacy Internet Explorer / compatibility-mode browsers. DLL loading behavior (LoadLibraryEx pattern observed) may be exploitable if vulnerabilities exist in the control. Debug path disclosure aids attacker reverse engineering. Deprecated technology increases risk of unpatched known vulnerabilities.

Evidence:

```
PrintControl.INF content (excerpt): [Add.Code] PrintControl.dll=PrintControl.dll
[PrintControl.dll] RegisterServer=yes
CLSID={B7DA1CA9-1EF8-4831-868A-A767093EA685}
```

Recommendation: Remove the CAB file from the public web root immediately. Disable ActiveX usage across the application. Strip debug symbols from all production binaries. Migrate to modern browser-native PDF/print alternatives (e.g., HTML5/CSS print, PDF.js).

FIND-003: Legacy ASP.NET Framework Version Disclosure**HIGH****CVSS v3.1 Score:** 7.1

Description: Server HTTP response headers disclose the ASP.NET framework version in use. The X-AspNet-Version header reveals version 4.0.30319, and legacy directory paths confirm ASP.NET 2.0 components are also present (/aspnet_client/system_web/2_0_50727/). These versions are outdated and potentially outside Microsoft's mainstream support window.

Impact: Version disclosure enables attackers to target known CVEs specific to ASP.NET 4.0.x. Legacy ASP.NET versions may be susceptible to ViewState deserialization attacks, padding oracle attacks, and other documented .NET exploitation techniques. Combined with other findings, this significantly narrows the attacker's effort.

Evidence:

```
HTTP Response Header: X-AspNet-Version: 4.0.30319 X-Powered-By: ASP.NET
```

Recommendation: Upgrade to ASP.NET 4.8 or migrate to ASP.NET Core for long-term support. Remove version disclosure headers by adding in web.config and suppressing X-Powered-By in IIS configuration. Enable ViewState MAC protection and consider ViewState encryption.

FIND-004: Publicly Exposed RDP Service (Port 3389)**HIGH****CVSS v3.1 Score:** 8.1 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)

Description: TCP port 3389 (Remote Desktop Protocol) is accessible from the public internet on the assessed server IP. This was confirmed via port scanning during the reconnaissance phase. There is no indication of Network Level Authentication (NLA) enforcement or IP-based access restrictions.

Impact: Enables automated credential brute-force and password spraying attacks. Exposure to BlueKeep (CVE-2019-0708) and DejaBlue (CVE-2019-1181/1182) class vulnerabilities if patches are not current. Successful exploitation of weak or default credentials would result in full server compromise with administrative access.

Evidence:

```
nmap -sV -p 3389 [TARGET_IP] 3389/tcp open ms-wbt-server Microsoft Terminal Services
```

Recommendation: Restrict RDP access to specific IP addresses via firewall/security group rules (AWS Security Groups). Mandate VPN access before RDP is reachable. Enable Network Level Authentication (NLA). Enforce multi-factor authentication for all RDP sessions. Ensure all Windows Server patches (especially MS19-0708) are applied.

FIND-005: External Third-Party Script Inclusion (Supply Chain Risk)**MEDIUM****CVSS v3.1 Score:** 6.5 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

Description: The application loads a JavaScript file from an external, unverified CDN domain over unencrypted HTTP. If this external resource is compromised or the domain is taken over, arbitrary malicious JavaScript would execute in the context of all users' browsers with full access to session cookies, DOM, and credentials.

Impact: Complete session hijacking of all active user sessions. Credential harvesting via form field interception. Malware distribution to end users (watering hole attack). Defacement or data exfiltration. This represents a critical supply chain risk requiring zero attacker interaction with the server.

Evidence:

Page source contains:

Recommendation: Remove this external script dependency immediately. If third-party scripts are required, self-host them after security vetting. Implement a Content Security Policy (CSP) header with a strict script-src directive. Use Subresource Integrity (SRI) attributes for any retained third-party resources. Enforce HTTPS-only resource loading.

FIND-006: Improper HTTPS / TLS Configuration**MEDIUM****CVSS v3.1 Score:** 5.9 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

Description: HTTPS connections to the assessed domains fail or are inconsistently configured. Users and browsers fall back to unencrypted HTTP, transmitting session tokens, form data, and credentials in plaintext. No HSTS (HTTP Strict Transport Security) header was observed to prevent this downgrade.

Impact: All data transmitted over HTTP is susceptible to network-level interception (Man-in-the-Middle attacks). On shared or public networks (e.g., school Wi-Fi), session cookies can be captured, enabling account takeover without any server exploitation. Student and staff personal data may be exposed during transit.

Evidence:

HTTPS request to `https://erp.panchsheelschool.com` results in connection failure.
Application accessible via `http://` without redirection to HTTPS.

Recommendation: Obtain and deploy a valid TLS certificate (Let's Encrypt provides free certificates). Configure IIS to redirect all HTTP traffic to HTTPS (301 redirect). Add HSTS header: `Strict-Transport-Security: max-age=31536000; includeSubDomains`. Verify TLS configuration using SSL Labs (ssllabs.com/ssltest/).

FIND-007: Default IIS Page Exposure**MEDIUM****CVSS v3.1 Score:** 5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description: The root endpoint of the web server returns the default Microsoft IIS welcome page rather than the application. This indicates incomplete deployment configuration and reveals server technology details to unauthenticated users.

Impact: Confirms IIS 10 as the web server, reducing attacker reconnaissance effort. Suggests the server may have other default configurations that have not been hardened. Aids in infrastructure mapping and attack planning.

Evidence:

GET / HTTP/1.1 Host: `panchsheelsschool.com` Response: IIS Windows Server default welcome page

Recommendation: Remove the default IIS welcome page. Configure IIS to serve the application from the root. Suppress server version information in HTTP headers (remove `Server: Microsoft-IIS/10.0`). Conduct a full IIS hardening review against CIS Benchmark for IIS 10.

5. Risk Assessment Matrix

Risk Category	Rating	Contributing Findings
Information Disclosure	HIGH	FIND-001, FIND-002, FIND-003, FIND-007
Network Exposure	HIGH	FIND-004
Supply Chain Risk	MEDIUM-HIGH	FIND-005
Misconfiguration	HIGH	FIND-001, FIND-006, FIND-007
Legacy Technology	HIGH	FIND-002, FIND-003
Client-Side Risk	MEDIUM	FIND-002, FIND-005
Overall Exploitability	MODERATE	No direct exploitation confirmed
Chained Attack Risk	HIGH	All findings combined

6. Realistic Attack Chain

Step 1	Reconnaissance: Attacker identifies exposed subdomains and open ports including RDP (3389).
Step 2	Directory Enumeration: Directory listing reveals Crystal Reports paths, exposing application structure.
Step 3	Component Analysis: Attacker downloads and analyzes CAB files, extracting DLLs and INF configuration.
Step 4	Technology Fingerprinting: ASP.NET version header and legacy paths identify specific framework versions for CVE lookup.
Step 5	Supply Chain Vector: Compromise of external CDN domain would immediately inject malicious JS for all users.
Step 6	Network Interception: On insecure HTTP, MITM attack captures session tokens from users on shared networks.
Step 7	RDP Brute Force: Public RDP enables credential brute-forcing, potentially yielding administrative access.
Step 8	Full Compromise: Successful RDP access or chained exploitation leads to complete server compromise.

7. Evidence Summary

Test / Check	Status	Method
Directory Listing Enabled	CONFIRMED	Manual / ffuf
Crystal Reports Path Accessible	CONFIRMED	Manual enumeration
ActiveX CAB File Accessible	CONFIRMED	Manual / wget
PrintControl.cab Contents	CONFIRMED	Local static analysis
Debug Path in Binary	CONFIRMED	Local binary analysis (strings)
X-AspNet-Version Header	CONFIRMED	HTTP header inspection
ASP.NET 2.0 Path Exposed	CONFIRMED	Directory enumeration
External Script (HTTP CDN)	CONFIRMED	Page source review
RDP Port 3389 Open	CONFIRMED	nmap port scan
HTTPS Misconfiguration	CONFIRMED	Browser / curl testing
Default IIS Page	CONFIRMED	Manual browsing
Server-Side Exploitation (RCE/IDOR)	NOT ATTEMPTED	Out of scope

8. Remediation Roadmap

IMMEDIATE (0–7 days)

- Disable directory listing in IIS for /aspnet_client/ and all subdirectories.
- Remove or block public access to PrintControl.cab and all CAB/ActiveX files.
- Remove the external third-party script tag loading from cdn.jsinit.directfwd.com.
- Restrict RDP (port 3389) access via AWS Security Groups — allow only specific VPN IPs.
- Deploy a valid TLS certificate and configure HTTP-to-HTTPS 301 redirect.

SHORT-TERM (1–4 weeks)

- Upgrade ASP.NET from 4.0.30319 to ASP.NET 4.8 or migrate to ASP.NET Core.
- Remove X-AspNet-Version, X-Powered-By, and Server version headers from all responses.
- Enable and enforce Network Level Authentication (NLA) for RDP.
- Implement HSTS header (Strict-Transport-Security: max-age=31536000; includeSubDomains).
- Enable ViewState MAC protection and encryption in web.config.
- Remove the default IIS welcome page and configure proper application routing.

LONG-TERM (1–3 months)

- Migrate away from SAP Crystal Reports 13 ActiveX architecture to a modern reporting solution.
- Implement a Content Security Policy (CSP) with strict script-src directive.
- Conduct a full secure code review of the ERP application.
- Apply CIS Benchmark hardening for IIS 10 and Windows Server.

- Establish a periodic penetration testing schedule (at minimum annually).
- Implement centralized logging and alerting for authentication events.

9. Conclusion

The Panchsheel School web infrastructure exhibits a combination of security misconfigurations, legacy technology exposure, and inadequate network hardening that collectively result in a **HIGH overall risk rating**. While no direct server-side exploitation was confirmed or attempted during this assessment, the identified weaknesses provide a credible and realistic pathway for a motivated attacker to compromise user data, gain unauthorized access to the server, or deliver malicious content to students and staff.

The most critical priorities are: disabling directory listing, removing the external CDN script dependency, restricting public RDP access, and deploying valid TLS. These four actions alone would substantially reduce the immediate attack surface.

Responsible Disclosure Guidance

This report has been prepared for responsible disclosure to the Panchsheel School IT administration. No exploitation of production systems was performed. The findings should be communicated directly to the school's IT team or principal, along with this report, to enable remediation. Further active exploitation without explicit written authorization from the institution is outside the scope of ethical security research and may constitute an offence under applicable law (India IT Act, Sections 43 & 66).

Report ID: PST-2026-004 | Assessment Date: March 17–18, 2026 | Classification: CONFIDENTIAL

Prepared by: Sahil Maurya | Student, GLA University | sahilmaurya2575@gmail.com | sahilmaurya.in/portfolio | github.com/sahilmaurya2006

This document is intended solely for the use of Panchsheel School administration. Unauthorized distribution is prohibited.